

STRIDE Threat Model

Each finding was classified into a STRIDE category to understand the nature of the underlying weakness, not just its severity score.

Table 1: Metasploitable-2

Finding	STRIDE Category	Rationale
Bind Shell Backdoor Detection	Elevation of Privilege	Direct root shell, bypasses all authentication entirely.
UnrealIRCd Backdoor Detection	Elevation of Privilege	Same pattern - a planted backdoor gives instant root.
VNC Server weak password	Spoofing	Weak/default credential lets an attacker authenticate as the legitimate user.
rlogin / rsh Service Detection	Spoofing	These protocols trust source IP/hostname instead of real authentication.
Debian OpenSSH/OpenSSL RNG Weakness	Spoofing + Info Disclosure	Predictable key generation means keys can be guessed or cracked.
SSLv2/v3 Protocol Detection	Tampering + Info Disclosure	Obsolete protocol allows downgrade attacks and eavesdropping.
SSL Medium Cipher Suites (SWEET32)	Information Disclosure	Weak cipher can be broken to expose traffic.
SSL Certificate Cannot Be Trusted	Spoofing	No verifiable identity - enables man-in-the-middle impersonation.
Samba Badlock	Tampering + Elevation of Privilege	MITM against the SMB/LDAP authentication channel.
NFS Shares World Readable	Information Disclosure	Anyone can read shared files without authorization.

Finding	STRIDE Category	Rationale
Apache Tomcat AJP (Ghostcat)	Information Disclosure	Reads arbitrary files via the AJP connector; can lead further.
Apache Tomcat SEoL	Tampering (root cause)	Unpatched/unsupported software increases unpatched-vulnerability surface.
Ubuntu Linux SEoL	Root cause (all categories)	Unsupported OS receives no security patches, enabling all other findings.
ISC BIND downgrade / reflected DoS	Denial of Service	Service can be forced to downgrade or reflect traffic.
ISC BIND 9.x DoS	Denial of Service	Known crash/DoS condition in this BIND version.
DNS Cache Poisoning	Tampering + Spoofing	Attacker can forge DNS responses the target trusts.

BASIC MODEL DIAGRAM WITH TRUST BOUNDARY

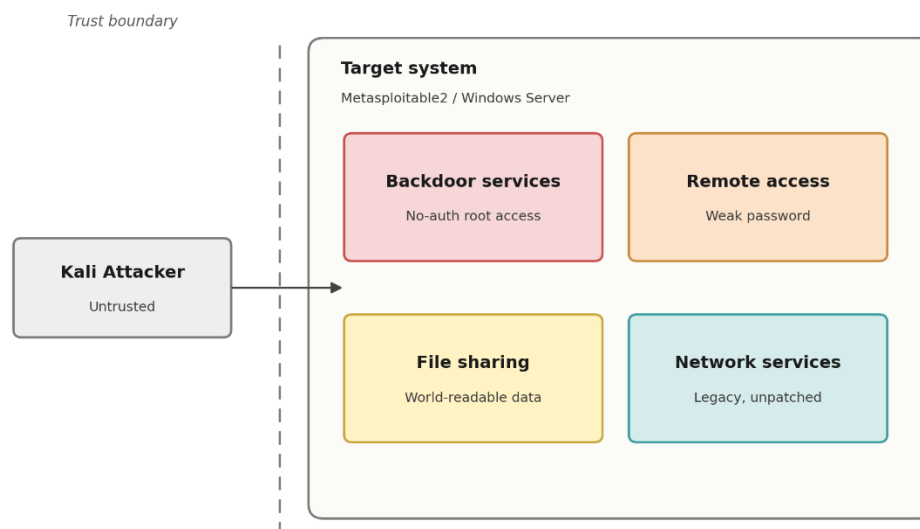


Figure 7: Basic Model Diagram

Table 2: Windows Server 2022

Findings	STRIDE Category	Rationale
SMBv3 Service Enabled (TCP 445)	Spoofing	Attackers can impersonate a legitimate SMB server or client to gain unauthorized access or capture authentication credentials.
Local & Domain User Credentials	Spoofing	Stolen or compromised credentials enable attackers to impersonate legitimate users and bypass authentication controls.
Critical System Files (C:\Windows & System32)	Tampering	Unauthorized users or malware can modify, delete, or replace files, compromising the integrity of system and user data.
Windows Registry Configuration	Tampering	Malicious changes to registry keys can alter system configurations, establish persistence, or disable security controls
Windows Event Logs	Repudiation	Attackers may delete or modify event logs to erase evidence of malicious activities, making actions difficult to trace or audit.
Shared Folders (SMB Network Shares)	Information Disclosure	Misconfigured or unsecured SMB shares may expose sensitive files and confidential information to unauthorized users.
Exposed Network Services (RDP, DNS, IIS)	Information Disclosure	Unsecured or vulnerable network services can leak system information, configurations, or sensitive data to attackers.
Windows Server 2022 Host Availability	Denial of Service	Attackers can exhaust server resources or exploit vulnerabilities, making services unavailable to legitimate users.
Built-in Administrator & Privileged Accounts	Elevation of Privilege	Compromising an administrator account allows attackers to gain elevated privileges and perform unauthorized system-level actions.